开源软件许可证合规检测分析报告

——基于 ScanCode Toolkit 对 Apache Commons Lang 的扫描

学号：f25011102　姓名：成御萌　课程：开源软件与合规　作业：平时作业 1

摘要：本报告选取 Apache 软件基金会（ASF）的开源项目 Apache Commons Lang，使用开源许可证合规检测工具 ScanCode Toolkit 32.5.0 对其全部 709 个文件进行许可证、版权与依赖扫描。扫描结果表明：698 个文件检出许可证信息，其中 695 个为 Apache-2.0，项目整体许可证自检合规；检测到的 7 个测试依赖均为宽松型或弱保护型许可证，与 Apache-2.0 兼容。主要关注点集中于 1 个历史文档混入的 Apache-1.1 文本、2 个贡献者协议（CLA）标记，以及 11 个不含许可证文本的二进制与数据文件，均不构成实际合规风险。安装过程主要障碍为 Windows 长路径限制，通过短路径虚拟环境解决。

1　选取的开源项目介绍

1.1　项目背景

Apache Commons Lang 是 Apache 软件基金会（ASF）Commons 项目组下的经典开源项目，提供对 Java 标准库 java.lang 包的扩展工具类，如 StringUtils、NumberUtils、ObjectUtils、ArrayUtils 等，广泛用于字符串处理、对象比较、随机数与时间操作等场景，被 Apache 生态及大量 Java 企业级项目直接依赖。项目自 3.9 版本起以 Java 8 为目标平台，并在 JDK 8、11、17、21、25 等 LTS 版本上持续测试。

该项目的许可证为 Apache-2.0，其代码文件头部均包含标准 Apache License 2.0 声明。选择本项目的原因：其一，作为 ASF 顶级项目，其许可证管理与合规实践具有代表性；其二，项目规模适中（709 个文件），便于完整扫描；其三，其依赖与文档结构完整，能够充分检验工具的检测能力。

1.2　扫描对象信息

本次扫描对象为 Apache Commons Lang 的 GitHub 主分支（main），提交哈希 32dc4c5（2026-10-07），共 709 个文件、72 个目录，源码总规模约数万行 Java 代码，含 src/main（源码）、src/test（单元测试）、src/site（站点文档）等目录。项目官网为 https://commons.apache.org/proper/commons-lang/。

2 许可证合规工具的安装过程及遇到的问题

2.1 工具选择

本报告选用 ScanCode Toolkit（32.5.0 版）作为合规检测工具。ScanCode 由 nexB 公司开发维护，隶属 AboutCode 开源项目群，工具本身采用 Apache-2.0 许可证。它可同时检测代码中的许可证、版权声明与包依赖清单，输出 JSON、HTML、SPDX 等多种格式报告，是参考工具列表中检测能力最全面、报告信息最完整的工具之一，也便于命令行集成与结果复核。

2.2 安装过程

安装环境为 Windows 操作系统与 Python 3.13。通过包管理器安装：pip install scancode-toolkit。安装完成后以 scancode --version 验证，得到版本号 32.5.0。

2.3 安装及准备过程中遇到的问题

安装过程共遇到三个问题，均通过针对性方案解决：

（1）Windows 长路径限制：首次在系统 Python 环境中安装时，由于 site-packages 目录路径过长，加上 ScanCode 内置许可证规则库中存在超长文件名，安装报错 OSError: No such file or directory。解决方法是在 D 盘创建短路径虚拟环境 D:\scancode-venv 并重新安装，安装随即成功。

（2）网络下载中断：安装过程中一次 126 MB 的安装包下载因网络连接被重置而中断，重试后正常完成。

（3）GitHub 源码获取：克隆 Apache Commons Lang 源码时需要经本地代理访问 GitHub，且 Windows 自带 schannel TLS 后端报连接异常，通过为 git 指定 openssl 后端后克隆成功。

3　工具输出的检测报告

3.1　扫描概况

扫描命令为：scancode -l -c -p --json-pp scan-report.json --html-app scan-report.html --ignore "*.git*" commons-lang。其中 -l 检测许可证、-c 检测版权、-p 检测包与依赖。扫描概况如表 1 所示。

表 1　扫描概况

扫描对象	Apache Commons Lang（main 分支，commit 32dc4c5，2026-10-07）
扫描范围	709 个文件、72 个目录（排除 .git）
检测项	许可证（-l）、版权（-c）、包与依赖（-p）
工具版本	ScanCode Toolkit 32.5.0（输出格式 4.1.0，SPDX 许可证列表 3.27）
扫描耗时	约 6.8 小时（多进程并行）
输出格式	JSON（1.2 MB）、HTML

数据来源：ScanCode 32.5.0 扫描报告（scan-report.json，2026-10-09 生成）。

3.2　许可证检测结果

在 709 个文件中，698 个（98.4%）检出明确的许可证表达式，其中 695 个为 Apache-2.0 单一许可证；3 个文件为组合表达式（2 个含贡献者协议文本 generic-cla，1 个含 Apache-1.1）。许可证匹配共 709 次，Apache-2.0 匹配 704 次且置信度均为 100%。各许可证分布如图 1 所示。

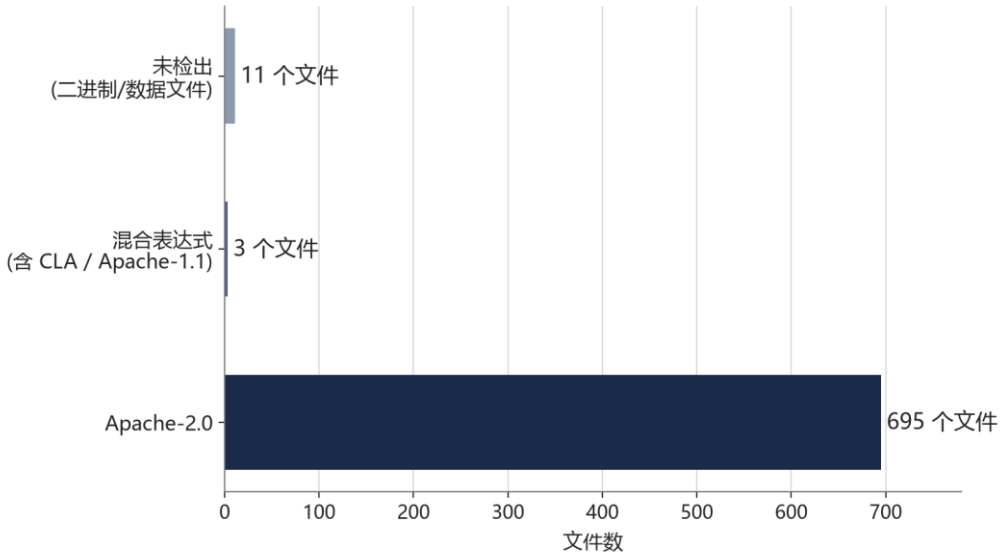


图 1　扫描文件许可证分布（按文件数，共 709 个文件）

数据来源：ScanCode 32.5.0 扫描报告；其中“混合表达式”含 apache-2.0 AND generic-cla（2 个）与 apache-2.0 AND apache-1.1（1 个），“未检出”为不含许可证文本的二进制与数据文件。

许可证检测的明细如表 2 所示。

表 2　许可证检测结果明细

许可证表达式	文件数	置信度	涉及文件说明
apache-2.0	695	100%	全部源码、测试、配置及文档文件
apache-2.0 AND generic-cla	2	100%	CONTRIBUTING.md 等贡献者协议文本
apache-2.0 AND apache-1.1	1	75%	站点历史报告（clirr 兼容性报告）
未检出（无表达式）	11	—	PNG/XCF 图片、JSON 数据、历史发布说明等
合计	709	—	—

数据来源：ScanCode 32.5.0 扫描报告（license_detections 与文件级 detected_license_expression 统计）。

3.3　包、依赖与版权检测

工具识别出项目包元数据 commons-lang3（版本 3.21.1-SNAPSHOT，Maven 类型），并解析出 7 个测试依赖（scope=test）。由于未下载依赖源码，工具给出的依赖许可证字段为空，其许可证需结合官方元数据核实，结果如表 3 所示。此外共检出 2 条版权声明，均为 The Apache Software Foundation。

表 3　测试依赖及其许可证（结合官方元数据）

依赖	版本	许可证	许可证类型
junit-jupiter（JUnit 5）	5.14.2	EPL-2.0	弱保护型
junit-pioneer	1.9.1	EPL-2.0	弱保护型
easymock	5.6.0	Apache-2.0	宽松型
mockito-inline	4.11.0	MIT	宽松型
commons-text	1.15.0	Apache-2.0	宽松型
jmh-core / jmh-generator-annprocess	1.37	GPL-2.0 with Classpath exception	弱保护型
合计	—	7 个依赖均为宽松/弱保护型	与 Apache-2.0 兼容

数据来源：ScanCode 32.5.0 扫描报告（依赖 purl 清单）与 Apache Commons Lang 官方依赖页（许可证元数据），2026-10-09 核验。

4 检测报告分析

4.1 合规性结论

综合扫描结果，Apache Commons Lang 的许可证合规状况良好：源码、测试与配置文件的许可证声明高度统一（98.4% 的文件检出 Apache-2.0），与项目对外声明的许可证完全一致；全部测试依赖均为宽松型或弱保护型许可证，与 Apache-2.0 的再分发条款兼容。作为 ASF 维护项目，其许可证头规范化程度较高，合规管理流程可作开源项目参考。

4.2 需要关注的点

（1）历史文档中的 Apache-1.1 文本：站点目录下 1 个历史兼容性报告同时检出 apache-2.0 与 apache-1.1，置信度仅 75%，属于历史遗留文档中的旧许可证引用，不涉及源代码分发，无需整改。

（2）贡献者协议（CLA）标记：CONTRIBUTING.md 等 2 个文件含 generic-cla 文本。该标记并非软件许可证，而是 ASF 的贡献者协议说明，ScanCode 将其与 Apache-2.0 并列检出属于正确的文本识别。

（3）未检出许可证的文件：11 个文件（占 1.6%）无许可证表达式，均为图片、JSON 数据、历史发布说明等非源代码文件。Apache-2.0 的合规义务主要面向可分发代码，此类资源文件在 ASF 项目中普遍存在，不构成合规缺口。

（4）依赖许可证的核实依赖外部元数据：工具对依赖仅解析出坐标（purl），许可证字段为空，需要结合官方依赖页或 Maven 元数据补全。这是工具不下载依赖源码时的固有限制，合规审查时须补充依赖级 SBOM 扫描。

4.3 工具能力评价

ScanCode Toolkit 在许可证识别上表现可靠：Apache-2.0 的 704 次匹配全部达到 100% 置信度，对 CLA 协议文本与旧许可证的区分也较为准确；JSON 报告结构完整、字段规范，便于程序化分析。其局限包括：全量扫描耗时较长（本项目约 6.8 小时）；依赖级许可证需外部元数据补全；HTML 报告功能已弃用（官方建议改用 ScanCode Workbench），实际交付以 JSON 数据为准。

4.4 合规建议

对本项目无需整改。若将其作为组件引入商业产品分发，建议：保留 NOTICE.txt 与 LICENSE.txt；在 SBOM 中记录 7 个测试依赖的许可证（其中 JMH 的 GPL-2.0 with Classpath exception 仅作用于测试代码，不进入发行物）；将合规扫描接入 CI 流水线，以 JSON 输出存档。

5 结论

本报告完成了对 Apache Commons Lang 的许可证合规检测与分析。ScanCode Toolkit 安装配置顺利（3 个环境问题均有明确解法），扫描结果显示项目许可证自检合规，无需要整改的合规风险。该实践验证了开源合规检测工具“扫描—出报告—分析—归档”的完整工作流，为后续开源项目的合规管理提供了可复用的方法。

参考来源

Apache Commons Lang 项目主页：https://commons.apache.org/proper/commons-lang/
Apache Commons Lang 官方依赖与许可证页：https://commons.apache.org/proper/commons-lang/dependencies.html
ScanCode Toolkit 仓库：https://github.com/nexB/scancode-toolkit
Apache License 2.0 文本：https://apache.org/licenses/LICENSE-2.0
ScanCode 32.5.0 扫描报告（本地生成）：D:\祝欣荣老师的开源课程作业\扫描工作\scan-report.json